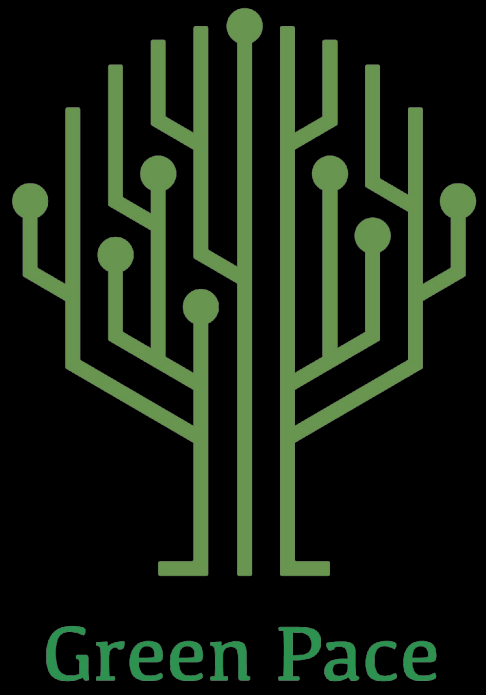
Green Pace

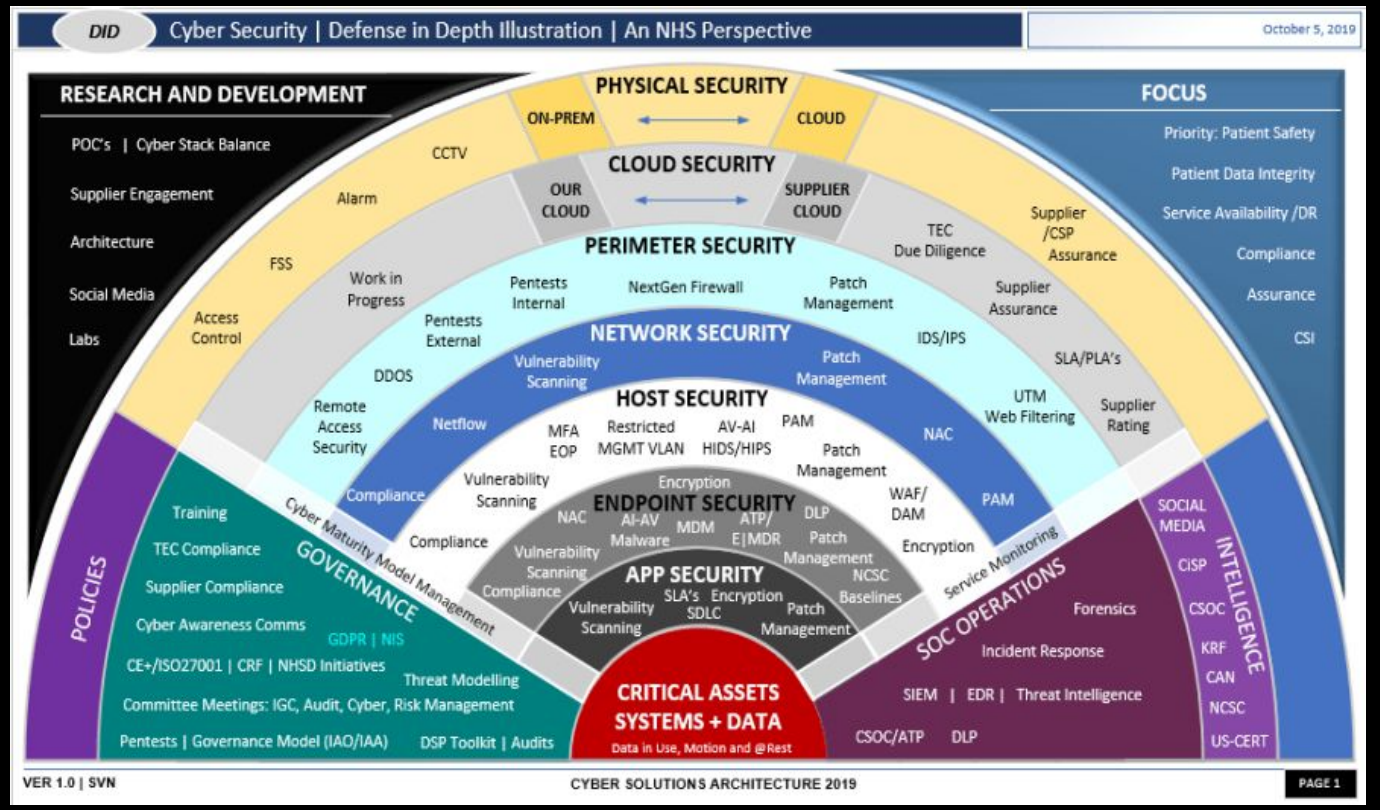
Security Policy Presentation

Developer: Daniel Karnaukh



OVERVIEW: DEFENSE IN DEPTH

Software development at Green Pace requires consistent implementation of secure principles to all developed applications. The purpose of this policy is to implement those principles in a concrete form.



Green Pace

THREATS MATRIX

Likely: likely to happen but low priority

Low priority: unlikely to happen and low priority

Unlikely: unlikely to happen but with a high priority

Priority: likely to happen with a high priority

Likely STD-002-CPP STD-007-CPP	Priority STD-003-CPP STD-004-CPP STD-005-CPP STD-008-CPP STD-009-CPP
Low priority STD-001-CPP STD-006-CPP	Unlikely STD-010-CPP

Green Pace

10 PRINCIPLES

1	Validate Input Data	STD-002-CPP, STD-003-CPP, STD-004-CPP
2	Heed Compiler Warnings	STD-008-CPP, STD-009-CPP
3	Architect and Design for Security Policies	STD-001-CPP
4	Keep It Simple	
5	Default Deny	
6	Adhere to the Principle of Least Privilege	
7	Sanitize Data Sent to Other Systems	
8	Practice Defense in Depth	STD-010-CPP
9	Use Effective Quality Assurance Techniques	STD-005-CPP, STD-006-CPP, STD-007-CPP
10	Adopt a Secure Coding Standard	



CODING STANDARDS

ID	Description	Severity	Likelihood
STD-005-CPP	Do not read uninitialized memory.	High	Probable
STD-009-CPP	Do not depend on the order of evaluation for side effects.	Medium	Probable
STD-003-CPP	Do not attempt to create a std::string from a null pointer.	High	Likely
STD-004-CPP	Prevent SQL injection.	High	Likely
STD-002-CPP	Detect errors when converting a string to a number.	Medium	Unlikely
STD-008-CPP	Guarantee that container indices and iterators are within the valid range.	High	Likely
STD-007-CPP	Do not abruptly terminate the program.	Low	Probable
STD-010-CPP	Wrap functions that can spuriously wake up in a loop.	Low	Unlikely
STD-001-CPP	Do not declare or define a reserved identifier.	Low	Unlikely
STD-006-CPP	Understand the termination behavior of assert() and abort().	Medium	Unlikely

Green Pace

ENCRYPTION POLICIES

Encryption at rest	This protects data stored on hard drives, databases, and cloud storage. This policy applies because in the event of a data breach, such as either remotely or physically accessing the computer the data is stored on, unencrypted data is vulnerable to data leaks. Encrypted data is much safer even if the perpetrators get their hands on it.
Encryption in flight	This protects data transmitted over the internet. Bad actors can sometimes get in the middle of connections, or intercept data as it leaves or arrives. Encryption in transit allows private communications between server and client, or whoever is doing the communicating.
Encryption in use	Encryption in use secures the computation itself. For example, a cloud provider might process sensitive customer information inside a protected virtual machine to prevent the host or anyone else from accessing it.

Green Pace

TRIPLE-A POLICIES

Authentication	Authentication is making sure that users who do not have access to the server cannot get in in the first place. This typically manifests as user logins, but also authentication tokens.
Authorization	Authorization is making sure authenticated users can only access the information they are allowed to. For example, only administrators might be able to modify user accounts globally, with normal users only being able to modify their own user account.
Accounting	Accounting is taking logs of actions. All actions that are potentially dangerous, including authorized and more importantly unauthorized actions, should be logged. This is useful for investigating hacking attempts or admin abuse.

Green Pace

Unit Testing

MaxSizeIsGreaterThanOrEqualToSize

```
TEST_F(CollectionTest, MaxSizeIsGreaterThanOrEqualToSize)
{
  ASSERT_GE(collection->max_size(), collection->size());

  add_entries( count: 1);
  ASSERT_GE(collection->max_size(), collection->size());

  add_entries( count: 4); // total entries now 5
  ASSERT_GE(collection->max_size(), collection->size());

  add_entries( count: 5); // total entries now 10
  ASSERT_GE(collection->max_size(), collection->size());
}
```

Green Pace

Unit Testing

AtThrowsOutOfRangeException

```
TEST_F(CollectionTest, AtThrowsOutOfRangeException)
{
  add_entries( count: 5);
  ASSERT_THROW(collection->at( n: 10), std::out_of_range);
}
```

Green Pace

Unit Testing

CannotSetNegativeSize

```
TEST_F(CollectionTest, CannotSetNegativeSize)
{
  add_entries( count: 5);
  ASSERT_THROW(collection->resize( new_size: -1), std::length_error);
}
```

Green Pace

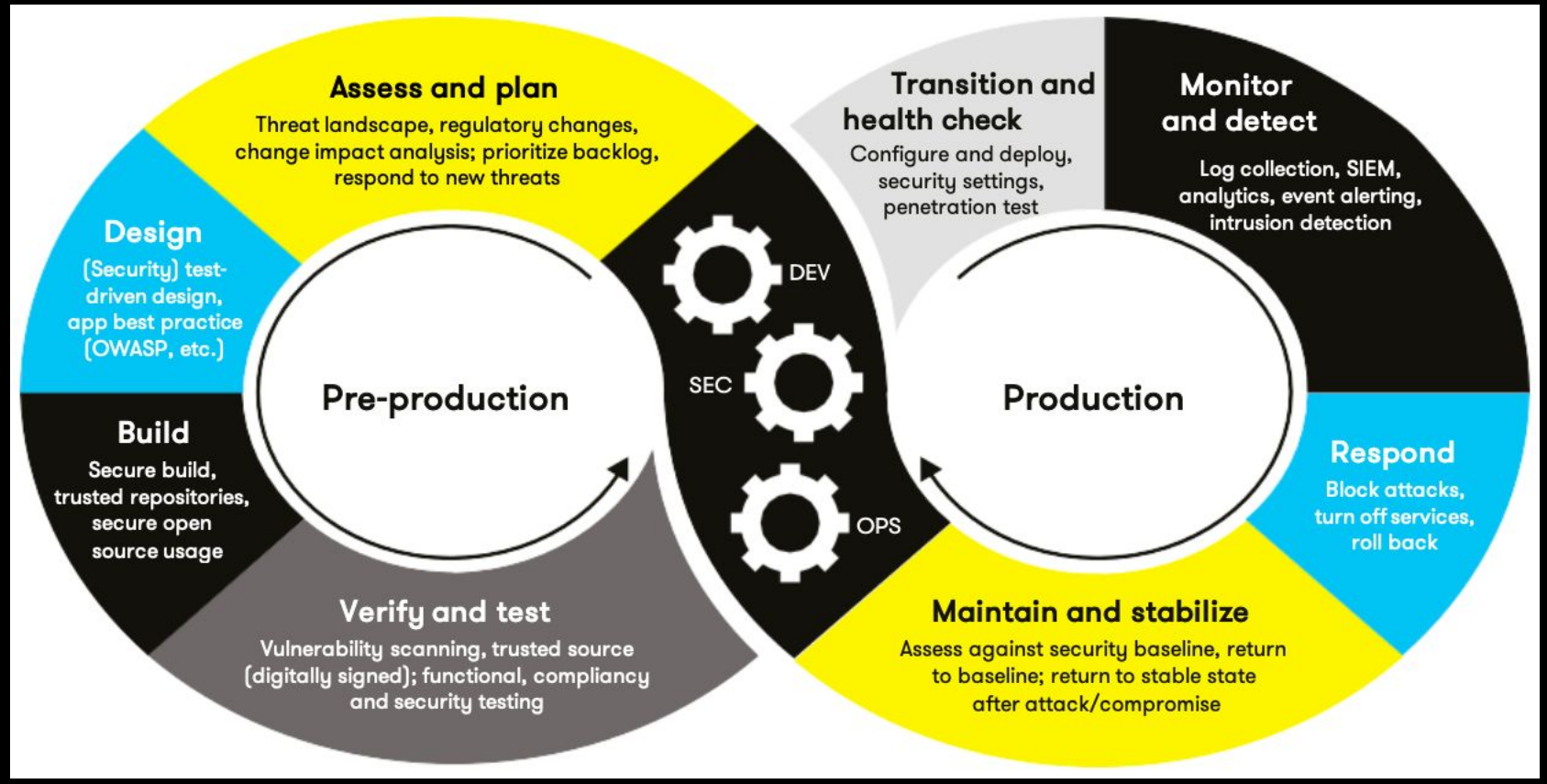
Unit Testing

ResizeToZero

```
TEST_F(CollectionTest, ResizeToZero)
{
  add_entries( count: 5);
  collection->resize( new_size: 0);
  ASSERT_EQ(collection->size(), 0);
}
```

Green Pace

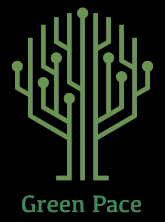
AUTOMATION SUMMARY



Green Pace

TOOLS

- Compilers
- Unit testing frameworks
- Linters
- Error monitors



RISKS AND BENEFITS

- Moving now:
  - Able to structure code better for security
  - Less open vulnerabilities in production
  - More time spent on security during initial development
  - More code dedicated to "inessential" stuff
- Moving later
  - Faster development
  - Smaller code size
  - Less initial security

Green Pace

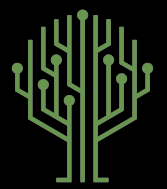
RECOMMENDATIONS

- Other languages
- Memory safety
- MEMORY SAFETY
    - Rust
- Protocol security
- Code style

Green Pace

CONCLUSIONS

- Do not declare or define a reserved identifier.
- Detect errors when converting a string to a number.
- Do not attempt to create a std::string from a null pointer.
- Prevent SQL injection.
- Do not read uninitialized memory.
- Understand the termination behavior of assert() and abort().
- Do not abruptly terminate the program.
- Guarantee that container indices and iterators are within the valid range.
- Do not depend on the order of evaluation for side effects.
- Wrap functions that can spuriously wake up in a loop.



REFERENCES

- National Security Agency, & Cybersecurity and Infrastructure Security Agency. (2025, June). Memory safe languages: Reducing vulnerabilities in modern software development. https://media.defense.gov/2025/Jun/23/2003742198/-1/-1/0/CSI_MEMORY_SAFE_LANGUAGES_REDUCING_VULNERABILITIES_IN_MODERN_SOFTWARE_DEVELOPMENT.PDF

Green Pace